

Analisi dei log con Splunk Enterprise

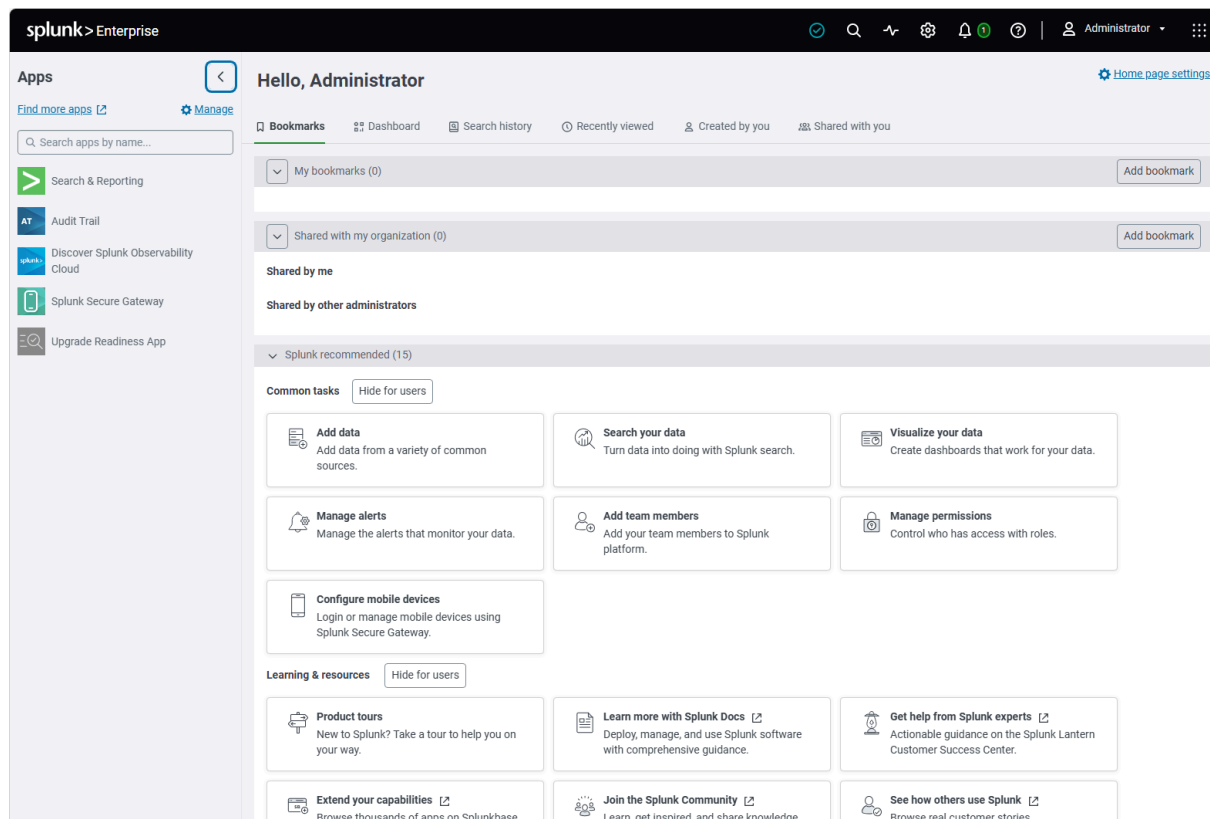
Santi Lo Faro

Introduzione

In questo laboratorio è stato utilizzato Splunk Enterprise, all'interno di una Virtual Machine Windows server 2022, per analizzare un insieme di log. L'obiettivo dell'attività è stato acquisire familiarità con le funzionalità di ricerca e analisi offerte da Splunk attraverso la creazione di query dedicate all'identificazione di eventi di sicurezza e anomalie presenti nei log.

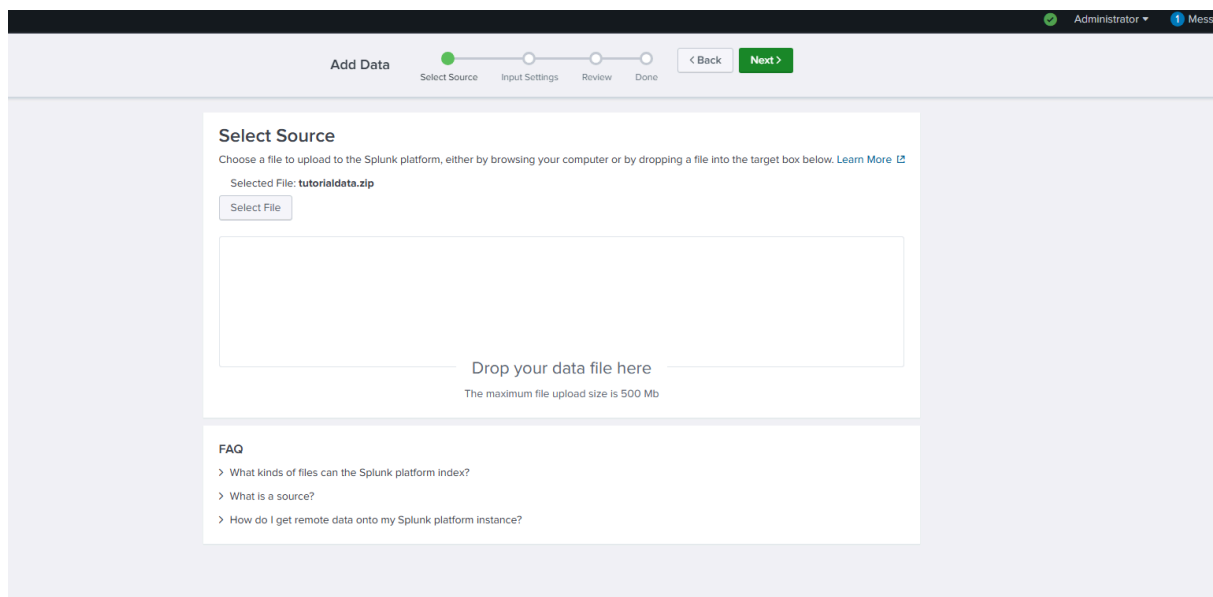
Splunk è una piattaforma SIEM (Security Information and Event Management) che permette di raccogliere, indicizzare, cercare e analizzare grandi quantità di dati provenienti da sistemi informatici, applicazioni e dispositivi di rete. Grazie al proprio motore di ricerca, Splunk consente di individuare rapidamente eventi sospetti, tentativi di accesso non autorizzati, errori applicativi e molte altre informazioni utili per il monitoraggio della sicurezza.

Durante il laboratorio sono stati importati i dati contenuti nel file tutorialdata.zip e successivamente sono state sviluppate diverse query per analizzare eventi relativi a autenticazioni SSH e accessi Web.



Importazione dei dati

La prima fase dell'attività ha riguardato il caricamento del dataset all'interno della piattaforma Splunk. Tramite la funzione *Add Data* è stato selezionato il file *tutorialdata.zip* contenente i log utilizzati durante il laboratorio.



Durante la procedura di configurazione è stato assegnato il nome host *TutorialData* e i dati sono stati indicizzati all'interno dell'indice denominato *tutorial*. L'indice rappresenta il contenitore logico utilizzato da Splunk per organizzare e memorizzare gli eventi importati.

Add Data

< Back

Review >

Select Source

Input Settings

Review

Done

Input Settings

Optionally set additional input parameters for this data input as follows:

Source type

The source type is one of the default fields that the Splunk platform assigns to all incoming data. It tells the Splunk platform what kind of data you've got, so that the Splunk platform can format the data intelligently during indexing. And it's a way to categorize your data, so that you can search it easily.

Automatic

Select

New

Host

When the Splunk platform indexes data, each event receives a "host" value. The host value should be the name of the machine from which the event originates. The type of input you choose determines the available configuration options. [Learn More](#)

☒ Constant value

☐ Regular expression on path

☐ Segment in path

Host field value

TutorialData

Index

The Splunk platform stores incoming data as events in the selected index. Consider using a "sandbox" index as a destination if you have problems determining a source type for your data. A sandbox index lets you troubleshoot your configuration without impacting production indexes. You can always change this setting later. [Learn More](#)

Index

tutorial

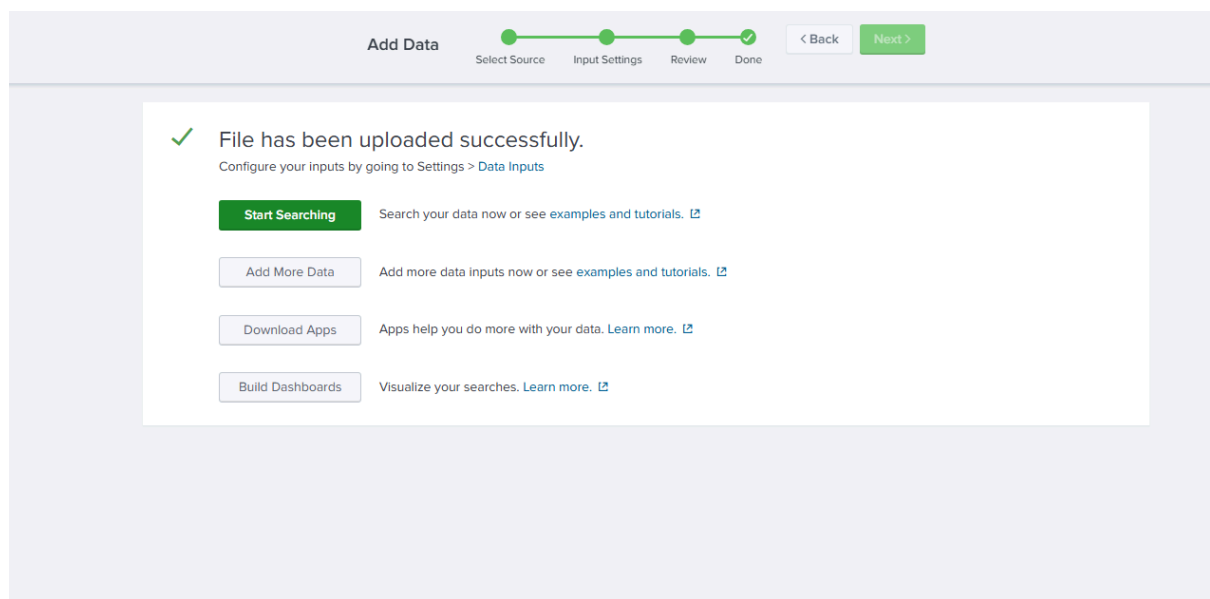
Create a new index

FAQ

> How do indexes work?

> How do I know when to create or use multiple indexes?

Una volta completata la configurazione, Splunk ha eseguito l'indicizzazione dei dati rendendoli immediatamente disponibili per le successive attività di ricerca e analisi.



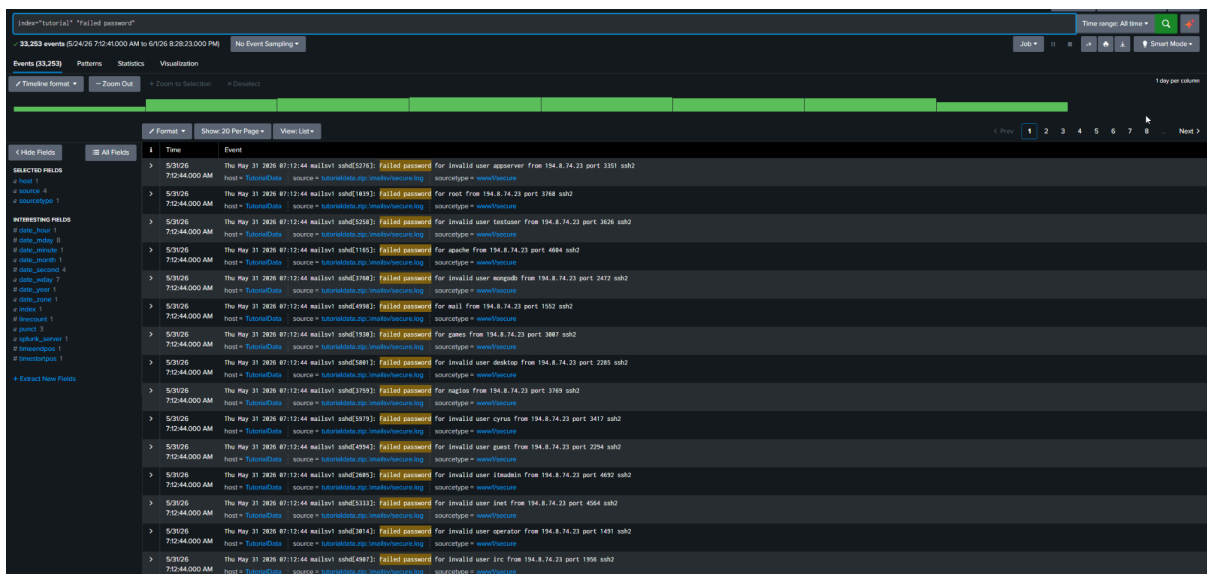
Ricerca dei tentativi di accesso falliti

La prima attività richiesta consisteva nell'individuare tutti i tentativi di autenticazione SSH non riusciti.

Per effettuare la ricerca è stata utilizzata la seguente query:

```
index="tutorial" "Failed password"
```

La query ricerca all'interno dell'indice *tutorial* tutti gli eventi che contengono la stringa *Failed password*. Questo messaggio viene generato dal servizio SSH quando un utente tenta di autenticarsi utilizzando credenziali non valide oppure tentando l'accesso con account inesistenti.



L'analisi dei risultati mostra numerosi tentativi di autenticazione fallita provenienti da differenti indirizzi IP. Nei log sono visibili il timestamp dell'evento, il nome utente utilizzato durante il tentativo di accesso e l'indirizzo IP sorgente dal quale è stata effettuata la connessione. Si osservano inoltre numerosi tentativi contro account comuni come *root*, *apache*, *mail*, *mongodb* e altri utenti di sistema, comportamento tipico delle attività automatizzate di scansione e brute force eseguite da attaccanti o bot presenti su Internet.

L'analisi dei log evidenzia numerose aperture di sessione associate all'utente *djohnson*. Ogni evento riporta il timestamp dell'accesso e l'identificativo utente (*uid=0*) associato alla sessione. La presenza ripetuta di questi eventi indica che l'utente è stato utilizzato regolarmente per attività amministrative o operative sul sistema monitorato.

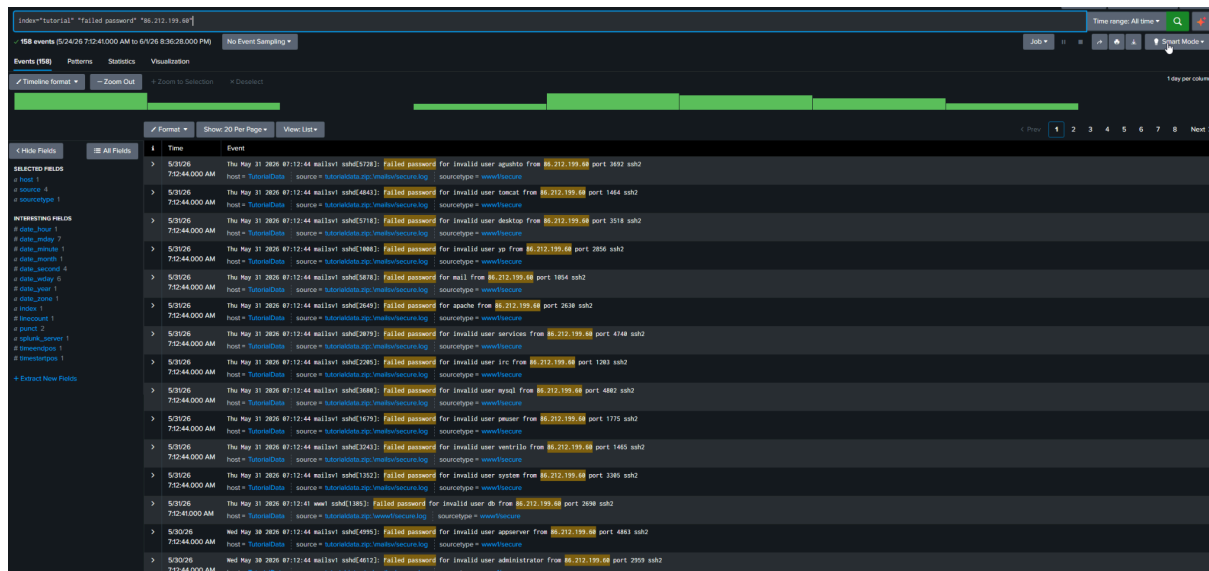
Ricerca dei tentativi di accesso falliti provenienti dall'indirizzo IP 86.212.199.60

La terza query richiedeva l'identificazione di tutti i tentativi di autenticazione SSH non riusciti provenienti da uno specifico indirizzo IP.

La query utilizzata è stata:

```
index="tutorial" "Failed password" "86.212.199.60"
```

Questa ricerca combina due criteri. Il primo filtra gli eventi relativi a password errate, mentre il secondo limita i risultati esclusivamente all'indirizzo IP indicato nella traccia dell'esercizio.



Dai risultati emerge che l'indirizzo IP 86.212.199.60 ha tentato numerosi accessi utilizzando differenti nomi utente, tra cui *administrator*, *apache*, *mysql*, *mail*, *desktop* e altri account di sistema. I tentativi sono stati effettuati utilizzando porte sorgente differenti, elemento che suggerisce un'attività automatizzata piuttosto che un normale utilizzo da parte di un utente legittimo.

Questo comportamento è tipico di attacchi di tipo brute force o credential stuffing, nei quali un sistema automatizzato tenta numerose combinazioni di utenti e password nel tentativo di ottenere accesso a un servizio SSH esposto in rete.

Individuazione degli indirizzi IP con più di cinque tentativi falliti

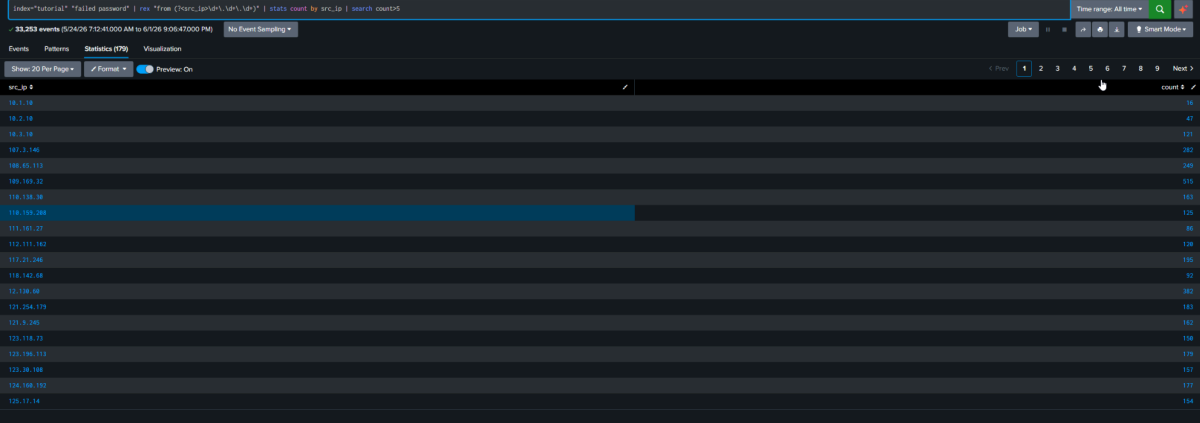
La quarta attività prevedeva l'identificazione degli indirizzi IP che hanno generato più di cinque eventi *Failed password*.

Poiché nei log l'indirizzo IP non era disponibile come campo già estratto da Splunk, è stato necessario utilizzare il comando *rex* per estrarre automaticamente l'indirizzo IP presente all'interno del messaggio dell'evento.

La query utilizzata è stata:

```
index="tutorial" "Failed password"  
| rex "from (?<src_ip>\d+\.\d+\.\d+\.\d+)"  
| stats count by src_ip  
| search count>5
```

Il comando *rex* estrae l'indirizzo IP presente dopo la parola *from* e lo salva nel campo denominato *src_ip*. Successivamente il comando *stats count by src_ip* conta il numero di eventi associati a ciascun indirizzo IP. Infine *search count>5* mantiene soltanto gli indirizzi che hanno effettuato più di cinque tentativi falliti.



The screenshot shows the Splunk search interface with the following query: `index="tutorial" "Failed password" | rex "from (?<src_ip>\d+\.\d+\.\d+\.\d+)" | stats count by src_ip | search count>5`. The results table displays 20 rows of data, each representing an IP address and its corresponding count of failed password attempts. The IP address `198.51.100.100` is highlighted in blue, indicating it has the highest count of 125.

src_ip	count
192.168.1.1	10
192.168.1.1	10
192.168.1.1	10
192.168.1.1	10
192.168.1.1	10
192.168.1.1	10
192.168.1.1	10
192.168.1.1	10
192.168.1.1	10
192.168.1.1	10
192.168.1.1	10
192.168.1.1	10
192.168.1.1	10
192.168.1.1	10
192.168.1.1	10
192.168.1.1	10
192.168.1.1	10
192.168.1.1	10
192.168.1.1	10
192.168.1.1	10
192.168.1.1	10

L'analisi evidenzia un numero elevato di indirizzi IP che superano abbondantemente la soglia dei cinque tentativi. Alcuni di essi presentano centinaia di eventi registrati, indicando attività persistenti e aggressive nei confronti del servizio SSH monitorato.

La distribuzione dei tentativi suggerisce la presenza di numerose sorgenti ostili che effettuano scansioni automatiche della rete e provano ad autenticarsi utilizzando account comuni o credenziali deboli. Questo tipo di comportamento rappresenta uno degli scenari più frequentemente osservati nei sistemi esposti su Internet.

Ricerca degli Internal Server Error

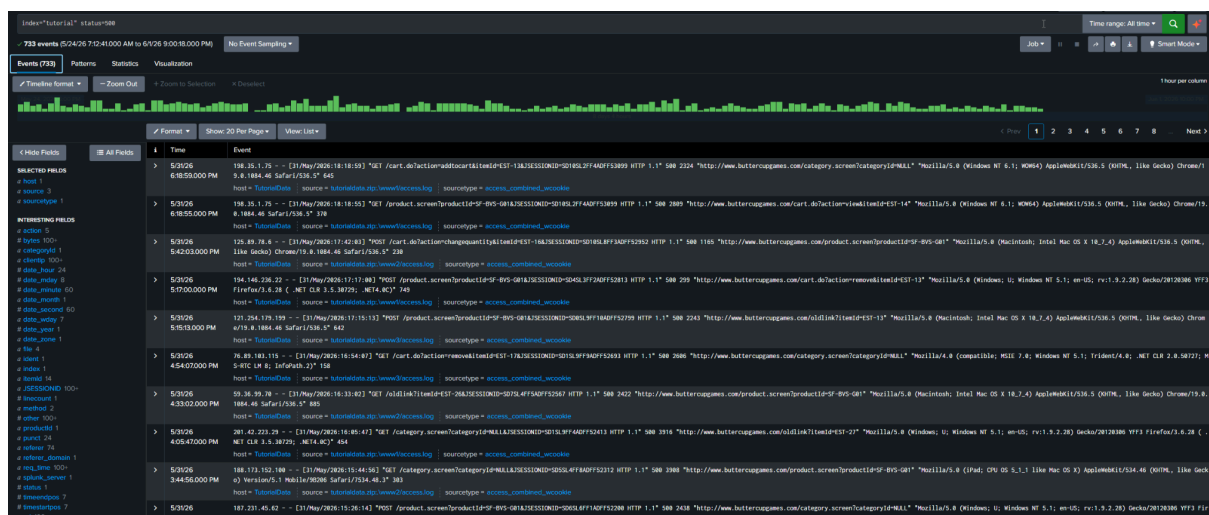
L'ultima attività prevedeva l'identificazione di tutti gli errori HTTP 500, comunemente noti come *Internal Server Error*.

Nel protocollo HTTP, il codice di stato 500 indica che il server ha incontrato una condizione inattesa che gli ha impedito di completare correttamente la richiesta del client. Questo tipo di errore può essere causato da problemi applicativi, errori nel codice, malfunzionamenti del database o configurazioni errate del server web.

Per individuare questi eventi è stata utilizzata la seguente query:

```
index="tutorial" status=500
```

La query filtra tutti gli eventi appartenenti all'indice *tutorial* che presentano un codice di risposta HTTP pari a 500.



L'analisi dei risultati mostra numerose richieste HTTP terminate con errore interno del server. Nei log sono visibili diversi URL dell'applicazione web, come ad esempio operazioni relative al carrello degli acquisti, alla gestione dei prodotti e alla navigazione tra le categorie del sito. Gli eventi riportano inoltre l'indirizzo IP del client, il browser utilizzato, la risorsa richiesta e il codice di errore restituito dal server.

La presenza di un numero significativo di errori HTTP 500 suggerisce l'esistenza di problematiche applicative o infrastrutturali che potrebbero influire negativamente sulla disponibilità del servizio e sull'esperienza degli utenti.

Analisi e conclusioni dei log mediante Intelligenza Artificiale

L'insieme dei log analizzati evidenzia diversi indicatori di interesse dal punto di vista della sicurezza informatica.

L'analisi dei log SSH mostra una quantità elevata di tentativi di autenticazione falliti provenienti da numerosi indirizzi IP differenti. Molti degli account presi di mira corrispondono a utenti comuni o a servizi frequentemente presenti nei sistemi Linux, come *root*, *apache*, *mysql*, *mail* e *administrator*. Questo comportamento è coerente con campagne automatizzate di brute force condotte da bot o sistemi compromessi che effettuano scansioni continue della rete alla ricerca di credenziali deboli.

L'indirizzo IP 86.212.199.60 rappresenta un esempio particolarmente significativo, poiché ha effettuato numerosi tentativi consecutivi utilizzando differenti nomi utente. Questo comportamento suggerisce un'attività ostile finalizzata all'accesso non autorizzato al sistema.

L'analisi delle sessioni SSH aperte con successo ha evidenziato invece l'attività dell'utente *djohnson*, il quale risulta aver effettuato diversi accessi legittimi al sistema. La presenza di sessioni correttamente aperte e chiuse indica un utilizzo regolare del servizio SSH da parte di utenti autorizzati.

Dal lato applicativo, la presenza di centinaia di eventi HTTP 500 evidenzia possibili criticità nell'applicazione web monitorata. Errori di questo tipo possono essere causati da eccezioni non gestite, problemi di comunicazione con il database, errori di configurazione o vulnerabilità applicative che generano condizioni inattese durante l'elaborazione delle richieste.

Combinando le informazioni ottenute, è possibile concludere che il sistema analizzato è esposto contemporaneamente a tentativi di accesso non autorizzati tramite SSH e a problematiche applicative rilevabili attraverso i log web. In un contesto reale sarebbe opportuno implementare meccanismi di protezione aggiuntivi, come sistemi di blocco automatico degli indirizzi IP sospetti, autenticazione multifattore per gli accessi amministrativi, monitoraggio continuo dei log e attività di troubleshooting sugli errori HTTP 500 per individuare e correggere le cause dei malfunzionamenti.

Conclusioni

Il laboratorio ha permesso di utilizzare Splunk come piattaforma di raccolta, indicizzazione e analisi dei log provenienti da differenti sorgenti. Attraverso l'uso delle query è stato possibile individuare tentativi di accesso falliti, sessioni SSH aperte con successo, attività sospette provenienti da specifici indirizzi IP, sorgenti che hanno effettuato numerosi tentativi di autenticazione e problematiche applicative evidenziate dagli errori HTTP 500.

L'attività ha dimostrato come l'analisi centralizzata dei log rappresenti uno strumento fondamentale per il monitoraggio della sicurezza, il rilevamento di comportamenti anomali e il supporto alle attività di incident response. Splunk consente infatti di trasformare grandi quantità di dati grezzi in informazioni utili per comprendere lo stato di salute dell'infrastruttura e individuare tempestivamente possibili minacce o anomalie operative.